Аудит переносимости — 2026-10-29

Что было в хорошем состоянии

Область	Наблюдение
Структура	`app/domain`, `app/http_api`, `app/realtime`, `app/services` — слои на месте
Тесты	10 файлов, **190 тестов проходят** на изолированном `DATA_DIR` без внешних сервисов
Контейнеризация	multi-stage `Dockerfile`, non-root `appuser`, HEALTHCHECK, том данных
Отказоустойчивость к отсутствию AI	офлайн-банк вопросов при пустом `GIGACHAT_CREDENTIALS`
Compose	fail-closed на обязательных секретах (`${VAR:?…}`)
Документация	README, ROADMAP, CHANGELOG, SECURITY, CONTRIBUTING

Разрывы и что сделано

#	Разрыв	Влияние	Закрыто
1	**`.env` закоммичен с рабочим ключом GigaChat**	утечка секрета, несмотря на `.gitignore`	файл убран из индекса, добавлен `gitleaks` в CI, инцидент описан в `docs/security/secrets.md`
2	**CI отсутствовал полностью**	190 тестов никто не запускал автоматически	`.github/workflows/ci.yml`: тесты, ruff, старт без AI, сборка образа + health, секреты, документация
3	Зависимости заданы диапазонами (`>=`, `<`)	две установки в разное время дают разные версии	`requirements.lock.txt` (37 пакетов) + `make lock`
4	Нет `Makefile`	команды разбросаны	`Makefile` с 17 целями
5	Нет проверки хоста и smoke-теста	«не работает» выяснялось после запуска	`scripts/doctor.sh`, `scripts/smoke-test.sh`
6	Нет проверки полноты документации	документы гниют молча	`scripts/docs-check.sh`
7	Нет архитектурного документа с границами	слои есть в коде, но не зафиксированы	`docs/architecture/system-context.md`
8	Нет спецификаций модулей	границы не проверяемы	`docs/modules/*` (3 спецификации + шаблон)
9	Нет матрицы «утверждение → проверка»	нельзя отличить доказанное от обещанного	`docs/verification/matrix.md`
10	`main.py`-независимая запись данных не документирована	две SQLite-базы без объяснения	`docs/database/storage.md`

Критично для владельца

Ротация ключей обязательна: `GIGACHAT_CREDENTIALS`, `SECRET_KEY`, `ADMIN_SECRET_KEY`, `CHEAT_TESTER_CODE`. Удаление файла не отзывает утёкший ключ.

Что осталось открытым

- Очистка истории git (`git filter-repo`) — решение владельца, не выполнена.
- Нет `/metrics` и SLO.
- Один процесс: комнаты в памяти, несколько реплик не поддерживаются.
- Нет автоматизированной проверки backup/restore SQLite.

Дополнение: что нашёл первый прогон CI

Симптом	Настоящая причина	Исправлено
Job «No committed secrets» падал с `missing gitleaks license`	`gitleaks/gitleaks-action@v2` для организаций требует платную лицензию и без неё не проверяет ничего	вместо action скачивается gitleaks закреплённой версии (8.28.0) и запускается напрямую: сканирование рабочего дерева — блокирующее, сканирование всей истории — информационное до отзыва ключа
Job «Tests, lint» падал на линте (324 замечания)	не было конфигурации ruff: результат зависел от версии, а блокирующим был весь строгий набор	`ruff.toml` с явным блокирующим набором (`E9`, `F`), 14 реальных замечаний исправлены; долг по стилю описан в `docs/development/code-style.md`
Контейнер не проходил health-check (`ADMIN_SECRET_KEY must be at least 12 characters`)	CI передавал короткий ключ, который валидатор конфигурации отвергает — то есть проверка работала правильно, а тестовые данные были неверны	в CI передаётся ключ нужной длины; проверка валидатора осталась
Проверки ставили «последние» pytest/ruff из PyPI	невоспроизводимость: набор правил и поведение меняются без изменения кода	`requirements-dev.txt` с точными пинами; CI ставит по нему

Дополнение: очистка истории от секретов (2026-10-29)

Полное сканирование всей истории (`gitleaks git`, все 7 репозиториев) нашло секреты в трёх:

Репозиторий	Что найдено	Где
ForgeBrainStorm	`.env` с ключом GigaChat (`client_id:client_secret`)	8 коммитов, файл `.env`
ForgeInterio	токен Telegram-бота и base64-ключ	`bot/main.py`, `DEPLOY_RENDER.md`
ForgeAezaAnalizer	`.env.before-telegram-*` с `JWT_SECRET`/`POSTGRES_PASSWORD`/`ADMIN_PASSWORD` (значения демонстрационные), дамп `db/auth.sqlite3`	2 коммита

ForgeCRM, ForgeRTKCRM, ForgeMadrigalProtocolLab — чисто. ForgePresentationHappy — единственное срабатывание ложное (названия анимаций в `pptx_animation_presets.json`).

Очистка: `git filter-repo` — удаление путей (`.env`, `.env.bak`, `.env.before-telegram-*`, `db/auth.sqlite3`) и замена секретных литералов на `REMOVED_SECRET`; все ветки переписаны и отправлены force-push. После перезаписи прогнаны тесты (BrainStorm 190 passed, Interio 15 passed, Aeza — набор в CI).

Оговорка про pull request'ы зафиксирована в `docs/security/secrets.md`: `refs/pull/*` — скрытые ссылки, force-push в них запрещён, поэтому ключи обязательно перевыпускаются, а остатки удаляются только через GitHub Support.